

Phishing Detection & Awareness Report

Prepared for: **Example Client Inc.**

Report Date: May 9, 2026

Analyst: Aarif Ahmad, Security Awareness Consultant

Contents

1	Executive Summary	2
2	Scope & Methodology	2
2.1	Scope	2
2.2	Methodology	2
3	Analysis of Phishing Email Samples	2
3.1	Sample 1 – “Urgent Account Verification”	2
3.2	Sample 2 – “Invoice Attached”	3
3.3	Sample 3 – “Monthly Newsletter from HR” (Safe Legitimate Email)	4
4	Risk Classification Criteria	4
5	Prevention & Awareness Guidelines for Employees	4
5.1	Do’s	4
5.2	Don’ts	5
5.3	Quick Reference – The S.T.O.P. Rule	5
6	Tools Used	5
7	Conclusion	6

Executive Summary

Phishing remains the most common cause of successful cyber attacks against businesses. Attackers craft emails that look legitimate to trick recipients into revealing passwords, downloading malware, or approving fraudulent payments.

This report analyses three real-world phishing email samples, highlights the red flags that give them away, and provides straightforward prevention guidelines. The goal is to turn every employee into a human firewall — someone who can spot a phishing email before clicking.

All email samples were obtained from public, educational sources and analysed using passive, read-only techniques. No live malicious links were followed, and no personally identifiable information (PII) is disclosed.

Overall finding: 2 out of 3 samples are confirmed phishing attempts; 1 is a legitimate email that uses some trust-building language but is safe.

Scope & Methodology

Scope

- **Emails analysed:** 3 samples (provided in the `evidence/` folder)
- **Analysis focus:** Visual indicators, sender domain, embedded links, header anomalies, and language patterns
- **Testing type:** Passive analysis only; no interaction with attacker infrastructure

Methodology

Each email was examined using the following steps:

1. **Visual inspection** – Sender name, subject line, grammar, urgency, generic greeting.
2. **Header analysis** – Using `Google Messageheader Tool` and `MXToolbox` to verify SPF, DKIM, and DMARC results, and to trace the true sender IP.
3. **Link inspection** – Hovering over links (without clicking) to reveal the real destination URL; checking for misspellings, unusual domains, or IP-based links.
4. **Context evaluation** – Does the email match the recipient's normal work flow? Are the requests unusual?

All tools used are free and publicly available: `Google Messageheader`, `MXToolbox Email Header Analyzer`, and browser hover inspection. No proprietary tools were required.

Analysis of Phishing Email Samples

Sample 1 – “Urgent Account Verification”

Risk classification: **Phishing**

Email summary:

Subject: Urgent: Your Account Will Be Locked
From: Security Team <alerts@secure-update-mail.com>
Body: *Dear User, We noticed suspicious activity... Verify now: <http://secure-account-verify/.com> ...*

Indicators (Red Flags):

- **Sender domain is not from the company.** Official emails would come from the company's domain (e.g., @example-client.com), not a generic look-alike domain.
- **Urgency and fear language.** "Permanent account lock" and a 24-hour deadline pressure the recipient to act without thinking.
- **Suspicious link.** The hyperlink text looks like a login page, but the actual URL is a malicious domain. Hovering reveals a completely different destination.
- **Generic greeting.** "Dear User" instead of using the recipient's real name indicates a mass-mailed template.
- **Emotional trigger.** Emoji in subject line (🔒) is often used to grab attention and bypass rational judgment.

Why this is dangerous: Clicking the link would lead to a fake login page designed to steal the user's real password. Because it looks professional, one inattentive moment could compromise an entire business account.

Sample 2 – "Invoice Attached"

Risk classification: **Phishing**

Email summary:

Subject: Invoice #INV-6742 – Payment Required
From: Billing Department <billing@micr0soft-support.net>
Attachment: Invoice_INV6742.doc

Body: "Dear customer, your recent purchase has been processed. Please find attached invoice for your records. If you did not authorise this transaction, contact us immediately."

Indicators:

- **Domain spoofing.** "micr0soft-support.net" uses a zero instead of the letter "o" – a classic typo-squatting trick.
- **Unsolicited attachment.** A .doc file can contain malicious macros that download ransomware when opened.
- **Fake sense of urgency.** "If you did not authorise..." is a social engineering hook to make the victim panic and open the file.
- **Lack of personalised information.** No order number, no last 4 digits of credit card, no business details.

Why this is dangerous: Opening the attachment on a Windows machine with macros enabled could silently install malware, encrypt all files, or steal credentials. This is a common delivery mechanism for ransomware.

Sample 3 – “Monthly Newsletter from HR” (Safe Legitimate Email)

Risk classification: Safe

Email summary:

Subject: May Benefits Update – No Action Needed

From: HR <hr@example-client.com>

Link: <https://intranet.example-client.com/benefits-may>

Body: “Hi John, Please find attached this month’s wellness newsletter. No action required – have a great day!”

Why it is safe:

- **Sender domain matches the company’s official domain.**
- **Recipient name is used** – indicates internal targeting, not a random mass email.
- **No urgent request or threat.** The tone is calm and professional.
- **Link points to known internal domain.** Hovering shows exactly the same URL as the text, using HTTPS.
- **Consistent branding and footer.** The email includes standard company disclaimers and contact info.

This example shows that not all unexpected emails are malicious. Context and careful inspection are key.

Risk Classification Criteria

Rating	Meaning
Phishing	Clear indicators of fraud: spoofed domain, malicious link or attachment, urgent language, or credential theft attempt. Do not interact; report immediately.
Suspicious	Some unusual elements (e.g., misspelled domain, unexpected request) but insufficient evidence to confirm malicious intent. Requires further verification via other channels.
Safe	Email passes all checks: proper sender, expected content, no suspicious links. May still contain marketing or automated notifications, but no immediate threat.

Table 1: How emails are classified

Prevention & Awareness Guidelines for Employees

Do’s

- **Hover before you click.** Always check where a link really goes by hovering over it. If the address looks strange, don’t click.
- **Verify the sender’s domain.** Check the part after “@” carefully. Look for misspellings (e.g., “micr0soft” vs “microsoft”).

- **Use official channels.** If an email asks you to log in or update payment details, go directly to the website by typing the address yourself — never through an email link.
- **Report suspicious emails.** Use your company’s “Report Phishing” button or forward to IT. Quick reporting stops attacks before they spread.
- **Keep software updated.** A modern browser and up-to-date operating system can block many malicious links automatically.

Don’ts

- **Don’t act on urgency.** Real companies don’t threaten to delete your account in 24 hours via email.
- **Don’t open unexpected attachments.** Even PDFs or Word documents can carry viruses. Confirm with the sender via Teams or phone first.
- **Don’t reply to suspicious emails.** Responding confirms your email address is active, leading to more attacks.
- **Don’t share passwords or OTPs.** No legitimate organisation will ever ask for your password via email.
- **Don’t ignore security training.** Phishing techniques evolve; regular awareness is your best defence.

Quick Reference – The S.T.O.P. Rule

S Stop – Don’t rush. Phishing plays on emotion.

T Think – Does this request make sense? Would HR really ask for my password?

O Observe – Check the sender address, link URLs, and spelling.

P Protect – Report the email, delete it, and warn colleagues.

Tools Used

This analysis was performed entirely with free, browser-based resources:

- **Google Admin Toolbox Messageheader** – Analyzed SPF, DKIM, and DMARC status.
- **MXToolbox Email Header Analyzer** – Traced email transit path.
- **Browser hover inspection** – Revealed true link destinations without clicking.
- **VirusTotal (URL/attachment scanning)** – Used only for educational samples, not for live malicious files.

All tool outputs are documented in the **evidence/** folder of the accompanying GitHub repository.

Conclusion

Phishing attacks rely on deception, not technical exploits. The three examples in this report demonstrate how easily a well-crafted email can slip past spam filters. By training every employee to spot red flags — and by fostering a culture where it's safe to report mistakes — organisations can significantly reduce their risk.

Recommendation: Conduct quarterly simulated phishing exercises and update awareness materials based on real-world trends. Use this report as a starting point for your internal security awareness programme.